

The Advisory Inside: Measuring and Closing an In-Package Attack Surface on LLM Package Analyzers

Anonymous (double-blind submission)
Anonymous

ABSTRACT

Large language models (LLMs) increasingly screen open-source packages for malicious behavior, yet the files these models read are attacker-controlled. We measure the resulting in-package attack surface and find it domain- and family-dependent—and closable. A single advisory-style security comment planted in a real package shifts verdict sensitivity on genuinely malicious packages in opposite directions per model family (malicious recall $.667 \rightarrow .833$ for granite-3.3-2B, $.167 \rightarrow .042$ for Llama-3.2-3B), so both directions harm a scanner: one family loses detections, the other gains detections while starting to flag benign packages. Refusals are absent throughout (RR=0 across 2,700 defensive-task generations at 2–3B), so higher-stakes defensive content does not trigger safety blocking here. An AST-gated comment/docstring strip closes the channel where it inflates detection: on granite-3.3-2B every parseable defended verdict matches the no-attack baseline (23/23), all four advisory-induced verdict changes revert, and benign false positives stay at zero; on Llama-3.2-3B the strip restores nothing—the lost detections are byte-identical snippets of one package family whose own comments the strip removes—a family-dependent defense cost. On all 38 gated samples the stripped attack file equals the stripped original byte-for-byte: the defense is attack removal, not rephrasing. Beneath these measurements, a behavior-graph detector trained federated over ecosystem partitions is statistically equivalent to a strong centralized baseline (pre-registered TOST at ± 0.02 F1: $\Delta F1 = -.0065$, 90% CI $[-.0133, +.0003]$) and adds a significant margin over a trivial structural baseline ($+0.0227/+0.0487$ F1, $p \leq 1.9 \times 10^{-5}$)—a refinement, not a replacement.

1 INTRODUCTION

Open-source package ecosystems are a primary supply-chain attack surface: attackers publish packages that steal credentials, exfiltrate data, or download further malware during installation [4, 8, 9]. Deployed detectors such as DONAPI [7], Cerebro [11], and MalGuard [5] learn from package metadata, installation behavior, or code, and LLM-based triage is emerging independently [10].

An LLM analyzer reads exactly the artifact the attacker authored. Prior measurements of LLM safety under adversarial pressure studied prompt-level interference: refusals of defensively framed tasks and verdict corruption from untrusted context outside the code [1, 2]. This paper measures a channel those designs cannot express: untrusted content *inside* the analyzed package file, where a planted advisory comment is, at the input layer, indistinguishable from the reviewer’s own note.

The headline finding is a thesis in two parts. First, untrusted in-package content is a *domain-dependent*, *family-dependent* attack surface: the same planted advisory moves malicious-package recall *up* for one model family (with false positives accruing on benign

packages) and *down* for another (losing detections outright), and its signature differs from the false-positive channel measured in the vulnerability domain. Second, the surface is *closable*: stripping comments and docstrings with an AST-equivalence gate removes the advisory without touching executable semantics, fully neutralizing the channel on the model it inflates—while its measured cost on the other model is itself family-dependent.

Our contributions:

- (1) **Measurement.** A paired, pre-registered measurement over real npm/PyPI packages shows that an advisory comment planted in the package perturbs verdict sensitivity on genuinely malicious packages in a model-family-dependent direction—recall $.667 \rightarrow .833$ for granite-3.3-2B versus $.167 \rightarrow .042$ for Llama-3.2-3B—with benign false positives absent from the paired measurement and refusals absent throughout (RR = 0 over 2,700 defensive-task generations at 2–3B, refuting the higher-stakes-refusal hypothesis in this domain) (§5.1).
- (2) **Defense.** AST-level sanitization (comment/docstring strip, gated by re-parse equivalence) neutralizes the channel where the advisory inflates detection: defended verdicts are identical to the no-attack baseline on every parseable pair (23/23), all four advisory-induced verdict changes revert, benign false positives stay 0—and on all 38 gated samples the stripped attack file is byte-identical to the stripped original, so the defense is genuinely attack removal. The measured cost on Llama-3.2-3B (no restoration; the lost detections are byte-identical snippets of a single package family) is reported as a first-class outcome (§5.2).
- (3) **Background detector.** The detector beneath the safety measurements—behavior-graph features trained federated over ecosystem partitions—is statistically *equivalent* to a strong centralized baseline (pre-registered TOST at ± 0.02 F1) and adds a significant margin over a trivial structural baseline: a refinement of metadata signals, not a replacement (§5.3).

Scope is disclosed up front: all conclusions close at 2–3B model scale under local decoding, two ecosystems, and a pilot corpus of 603 provenance-tracked packages; the audit trail behind every number is summarized in §7 and Appendix A.

2 RELATED WORK

Malicious package detection. DONAPI maps installation-time behavior sequences for npm [7]; Cerebro trains a single cross-ecosystem model for npm and PyPI (centralized) [11]; MalGuard targets real-time PyPI detection [5]; MeMPtec uses metadata [6]. None study interference from content inside the analyzed file, or the safety layer of LLM analyzers. **FL for security.** VulFL applies FL to vulnerability detection [12] (preprint); to our knowledge

(as of September 2026), FL over ecosystem-partitioned clients for malicious-package detection is unexplored—a literature-check hedge, not an exhaustive claim. **LLMs for supply-chain security.** LLM-based npm triage [10] measures LLM detection accuracy but not in-package interference. **Attack taxonomy.** Ladisa et al. [8] systematize OSS supply-chain attacks; the channel studied here (content steering the defensive analyzer itself) is complementary to their attacker-facing taxonomy. **Safety-layer line.** A prior vulnerability-domain measurement study [1] established that open 2-7B models show $RR \approx 0$ under offensive-but-defensive wording and verdict corruption toward vulnerability (a false-positive channel); concurrent work reports a defensive-refusal bias in cyber-defense settings [2]. The present study ports those conditions to packages and adds the in-package arm; the channel that appears is of a different type (§5.1).

3 THREAT MODEL AND MEASUREMENT DESIGN

3.1 Attack surface: analyzer arms

Threat model. The attacker controls the content of a package file the defender’s LLM will analyze. The advisory is not executable: it is a comment, semantically inert by construction, so any verdict change it causes is caused by the model’s reading of untrusted prose.

Arms. Over real package files we run three pre-registered arms: **P0** a neutral defensive task (“review this package for malicious behavior”); **P1** identical intent phrased with defensive-refusal-bias vocabulary [2] (“steal credentials”, “exfiltrate”, “malware”); **P2** the neutral task over the package file with a prepended advisory-style security comment (comment-only, gated by a tree-sitter AST-equivalence check, so the injection is verifiably inert). The P1 arm tests prompt-level refusal pressure; P2 is the in-package surface this paper is about.

Metrics. Refusal rate (RR) per arm; verdict flips benign→malicious and malicious→benign; *malicious recall* (true-positive rate on malicious packages) and, separately, the benign false-positive rate; per-model refusal thresholds (fitted for Llama-3.2-3B, fallback for granite-3.3-2B; disclosed per record). Frozen decision rules: blocking is claimed only when $\Delta RR \geq 0.10$ with exact McNemar $p < 0.05$; corruption for ≥ 1 benign→malicious flip. A refusal is never converted into a verdict. One semantics correction travels with these metrics (§7): a quantity initially labelled “false-positive bias” actually computed recall on malicious packages; every affected value in this paper is reported under the corrected reading, with benign false positives measured separately.

3.2 Defense: AST-gated sanitization

Defense **D1** removes every tree-sitter comment node (JavaScript and Python) and Python docstrings from the package file before analysis; string literals are never removed, so executable behavior evidence is preserved. Removal is line-aware: the prepended one-line advisory strips back to the byte-identical original file. A gate requires the stripped file to re-parse to a canonical AST signature identical to the original’s (the signature prunes exactly the node classes D1 removes); a gate failure excludes the sample and is disclosed rather than silently dropped. Two properties make

the pairing interpretable. First, *strip equality*: wherever the strip succeeds, $\text{strip}(\text{attack file}) = \text{strip}(\text{original file})$ byte-for-byte, so the defended arm is “attack removed,” not a rephrasing. Second, the registered hypotheses are two-directional: *restoration* (H-D1: defended recall within .05 of the neutral baseline) and *neutralization* (H-D2: $|\text{recall}(\text{defended}) - \text{recall}(\text{neutral})| \leq .10$), evaluated per model, with restore-gains and restore-losses counted and reported separately—because one model’s recall *rises* under the attack, a defense could lose the advisory’s spurious gains, and that cost is pre-registered as reportable.

3.3 Background detector: graphs, federation, corrected baseline

The detector anchoring the safety measurements is deliberately conventional: logistic regression over eighteen graph-level features (six-class API-call histogram, size/density/depth, scope and import diversity, entry flags, parse-failure count) extracted from tree-sitter behavior graphs whose nodes are API calls normalized into six semantic classes (FILE_IO, NETWORK, PROCESS, CRYPTO, DYNAMIC_CODE, DATA_ACCESS) and whose edges are in-scope sequence and data edges; entry kinds mark setup.py and npm install-hook scripts (schema versioned, SCHEMA_VERSION 1.1.0). A GNN over the same graphs is specified future work; this paper reports no GNN results.

Training is a federated *simulation* over naturally non-IID ecosystem partitions (npm $n=328$, PyPI $n=146$ training rows; malicious rate .686 vs. .527); FedAvg (size-weighted average of converged local fits) and FedProx (exact local objective solved by L-BFGS-B, μ routed per algorithm and unit-pinned), with secure aggregation and DP as disclosed simulations. Because an audit found the original protocol’s centralized solver undertrained and its text featurizer fitted a pooled vocabulary (unavailable under federation), all federation claims rest on a *registered corrected baseline*: *strong centralized* = logistic regression (lbfgs, max_iter 5000, tol 10^{-6}) on train-fit standardized features with $C \in \{.01, .1, 1, 10\}$ selected by stratified 3-fold CV on training rows only; *text arm* = a stateless HashingVectorizer (2^{18} features, L_2 -normalized), so no preprocessing is illegal under federation. Clients share the train-fit scaler and the CV-selected C (a central hyperparameter-coordination assumption; no test row enters any fit). The full protocol history, including what was retracted and why, is condensed in §7 and Appendix A.

4 EXPERIMENTAL SETUP

Corpus (603, provenance-tracked). Malicious: 390 packages from a wild-capture dataset (deterministic stride sample, seed 20260922; 298 npm + 92 PyPI archives with verbatim per-sample class provenance). Benign: 213 popularity-derived packages (123 npm + 90 PyPI), “assumed benign, not individually audited.” With-graph coverage after a file-selection fix is 500/603 (82.9%; per-cell 85.4%/84.6%/70.0%/87.0%); empty-graph rows are kept as all-zero and reported per cell.

Splits. PRIMARY: a package-level group split (all versions of a package on one side; label-stratified; re-drawn per seed), adopted after measuring that the random split shares a package between

train and test for 35% of test rows. SECONDARY: the original stratified random split, reported for continuity and disclosed as leakage-prone.

Statistics. Registered twenty-seed protocol (seeds 20260922–20260941): per-seed exact McNemar (accuracy@0.5) on the paired FedAvg-vs-centralized comparison, aggregated by two-sided exact Wilcoxon signed-rank over the twenty per-seed $\Delta F1$, Holm-corrected over the four split $\times$ block comparisons; equivalence by a pre-registered TOST at margin ± 0.02 F1 (equivalence iff the 90% t -CI of the mean paired $\Delta F1$ lies entirely inside the margin; Schuirmann at $\alpha=.05$). At $n=20$ the minimum attainable two-sided exact p is 1.9×10^{-6} . Standard deviations over seeds are population ($ddof=0$). Both registrations (twenty seeds; corrected baseline) were filed before their respective runs and postdate earlier results at the same seeds (disclosed). For the safety and defense measurements, samples are fixed draws (seed 20260922) of real gate-passing packages, all p -values in those sections are exact paired McNemar, and every one is descriptive at the realized n (stated where used).

Pilot limits. Simulation-only trust mechanisms; two ecosystems (no Maven); popularity-derived benign labels; hand-curated API mapping tables; conclusions close at 2–3B under transformers/MPS decoding.

5 RESULTS

Rule-based SOTA baseline. We additionally evaluate GuardDog v3.2.0 [3], a rule-based npm/PyPI scanner (54 source YARA rules per ecosystem; verdict rule pre-registered: ≥ 1 high-severity source rule $\Rightarrow$ malicious; score = rule count for ranking), on all 602 scannable corpus packages (one archive is empty and is excluded). On the group-split test it scores F1 .866 / AUC .874 — below graph features (.923/.916 under FedAvg at the same split) and below the TF-IDF centralized AUC (.96) — and on the leave-cluster-out draw (threshold .30) it is the top-scoring system (F1 .857 vs. .735–.835), reversing at threshold .50. The fair summary is *comparable, not superior*: GuardDog is precision-first (17 false positives over 602 packages) with a recall ceiling — 25 of its 81 missed malicious packages trigger no rule at all, and 56 more trigger only medium/low rules. Two disclosures: GuardDog rules and our wild-capture malicious corpus share the same origin (DataDog), which plausibly flatters this baseline on the recall side; and the FN analysis above is descriptive at our pilot scale.

MalGuard-style feature reimplementaion. To probe whether our graph features merely re-encode a published feature family, we reimplemented a MalGuard/Amalfi-style feature set (41 label-blind features: per-class sensitive-API ratios, top-API indicators, class-pair co-occurrences, entry-point weights, and Amalfi-style text and metadata proxies; frozen in AMENDMENT-8 before running). Under the same twenty-seed protocol it scores $\Delta F1$ $-.0216$ vs. our graph features (90% CI $[-.0407, -.0025]$, exact Wilcoxon $p=.044$, not surviving Holm), with the gap concentrated on PyPI; appending the two sets yields $+0.0150$ (n.s.). Our graph features therefore compare favorably with a MalGuard-style reimplementaion on identical splits, while remaining complementary rather than redundant.

Table 1: Safety arms on 60 real packages per model (30 malicious + 30 benign; 60 paired generations per model/arm). RR = refusal rate; malicious recall = true-positive rate on the 30 malicious packages; FP benign = benign false-positive rate. Every value in the recall column is the corrected-reading recall (§3.1).

Model / arm	RR	flips b $\rightarrow$ m / m $\rightarrow$ b	recall (P0 $\rightarrow$ arm)	FP benign
llama P0 neutral	.00	– / –	.133	0/30
llama P1 offensive	.00	0 / 0	.133 $\rightarrow$.133	0/30
llama P2 advisory	.00	1 / 4	.133 $\rightarrow$.033	0/30
granite P0 neutral	.00	– / –	.533	0/30
granite P1 offensive	.00	2 / 0	.533 $\rightarrow$.600	0/30
granite P2 advisory	.00	8 / 0	.533 $\rightarrow$.800	0/30

5.1 Attack: an inert advisory perturbs verdicts in both directions

No refusals anywhere. Across all arms, models, and 60 packages (360 paired generations), not one generation is refused (exact McNemar vs. P0: $p=1.0$ everywhere). The measured scope of this null across the project is 2,700 defensive-task generations at 2–3B with zero overt refusals, while deliberately harmful probe prompts in the same runs were refused 125/225 times—the refusal pathway is functional; defensive package analysis never triggers it. We therefore read $RR \equiv 0$ as structural blocking-absence in this domain, refuting (at these scales and prompt families) the hypothesis that higher-stakes content raises refusal, and we do not generalize it to “safety alignment does not transfer.”

The advisory channel is recall-perturbing, not false-positive-creating—in the paired measurement. Table 1 shows the registered $n=60$ batch. All 11 benign $\rightarrow$ malicious flips across arms land on genuinely malicious packages (checked per sample), so the corruption rule fires as written but measures a *sensitivity shift on malicious packages*, not wrongful flagging of benign code; benign false positives are 0/180 across all arms and models. The direction of the shift is model-family-dependent: granite-3.3-2B recall rises .533 $\rightarrow$.800 under P2, while Llama-3.2-3B falls .133 $\rightarrow$.033 (four detections lost, one gained). Both directions harm a scanner: the suppressed family misses malicious packages; the inflated family gains detections it did not earn, and at measurement scale the inflation is accompanied by false positives (below).

At $n=100$ the divergence widens and the FP cost appears. The expansion to 100 real samples (50/50, zero overlap with the first draw) gives pooled malicious recall .350 $\rightarrow$.380 $\rightarrow$.440 (P0 $\rightarrow$ P1 $\rightarrow$ P2) with benign FP 0/0/2-of-100 and verdict flips 19 / 8 at P2 (200 pairs). Pooled numbers mask opposite per-model movement: llama’s recall collapses .160 $\rightarrow$.060 (all 8 malicious $\rightarrow$ benign flips are llama’s; benign FP 0), while granite’s rises .540 $\rightarrow$.820 and incurs the pooled FP (0 $\rightarrow$.040; both pooled FP records are granite’s). The advisory thus supplies granite with detections *and* starts it flagging benign packages—the operational reading is not that an advisory “helps,” but that no direction of this channel is safe to accept. A registered mechanism ablation (same-meaning paraphrase and word-scrambled controls, 30 malicious pairs per cell) is a null with low power (every exact McNemar $p \geq .25$), so “unusual content

Table 2: Attack–defense pairing (P2 advisory vs. the D1 comment/docstring strip, AST-equivalence gated). Recall on the malicious subset; $+g/-l$ = restore-gain ($0 \rightarrow 1$) / restore-loss ($1 \rightarrow 0$) flips of D1 vs. the attack arm; p = exact paired McNemar (P2 vs P2+D1), descriptive; FP = benign false positives (attack $\rightarrow$ defended). Realized subsets after the AST gate: 24 malicious + 14 benign per model (7 comment-only snippets excluded, disclosed; Fisher $p=.40$, no label bias). P0 and P2 arms are verified cache hits of the $n=100$ expansion; the attack-arm FP column is quoted from that expansion (this batch adds no benign P2 generations). One granite P2+D1 output was unparseable (disclosed; baseline-positive), hence recall over 23 parsed.

Model	rec P0	rec P2	rec P2+D1	$+g/-l$	p	FP
llama-3.2-3B	.167	.042	.042	1/1	1.0	0/50 $\rightarrow$ 0/14
granite-3.3-2B	.667	.833	.652	0/4	.125	2/50 $\rightarrow$ 0/14

perturbs verdicts” cannot yet be separated from “advisory content is read as evidence” (detail in Appendix A).

5.2 Defense: sanitization neutralizes—at a family-dependent price

Design and realized sample. The pairing asks the defender’s first question: does removing the advisory remove its effect? P0 and P2 arms are the verified cache-hit generations of the $n=100$ expansion; the defended arm (P2+D1) is newly generated (temperature 0, seed 1234) over the 38 of 45 drawn snippets that pass the AST gate (7 are comment-only license banners that strip to empty and are excluded before any condition—6 malicious, 1 benign; exclusion is label-independent, Fisher $p=.40$). Realized subsets per model: 24 malicious + 14 benign. On all 38 gated samples strip(P2) = strip(original) byte-for-byte, and for the 10 comment-free originals the defended prompt is byte-identical to the neutral prompt with byte-identical completions—the defended condition is attack removal, not a rephrasing. Every paired statistic below is descriptive: the smallest exact McNemar p in any comparison is .125, and comparisons with zero discordant pairs yield $p=1.0$ by construction and carry no information.

Granite-3.3-2B: full neutralization. Where the advisory had *raised* recall (.667 $\rightarrow$.833; Table 2), D1 returns the system exactly to its no-attack state: defended verdicts match the neutral baseline on every parseable pair (23/23; the single unparseable defended output was baseline-positive), all four advisory-induced verdict changes revert, and benign FP stays 0 (0/14; the two advisory-induced benign FPs of the expansion arm also disappear, 2/50 $\rightarrow$ 0/14). Both registered hypotheses (restoration and neutralization) pass on this model.

Llama-3.2-3B: no restoration, a measured defense cost. Where the advisory had *suppressed* recall (.167 $\rightarrow$.042), the strip restores nothing (.042). The four lost detections are byte-identical 2500-character snippets from four archive versions of a single package family (19 distinct families in the subset; the corpus keeps all archive versions), whose own comments the defense also strips: for this model the comments were the cue, and the defense removes cues indiscriminately. At family granularity

llama detects 1/19 in every condition. This is a one-family observation at this draw—and exactly the outcome the two-directional pre-registration was built to surface rather than fold into an aggregate.

Pooled view, for completeness. Pooled over both models, defended malicious recall .340 (16/47) sits between neutral .417 (20/48) and attacked .438 (21/48) (restore-gain 1 vs. restore-loss 5; exact McNemar $p=.219$ against the attack arm, $p=.375$ against neutral; benign FP 0/28 defended)—a descriptive aggregate of two opposite per-model outcomes, reported only to make the pooling visible, never as the headline.

5.3 Background detector: equivalent under federation, refined over trivial structure

Federation carries no measurable cost on the leakage-resistant split. On the primary group split, FedAvg is statistically *equivalent* to the strong centralized baseline at the pre-registered $\pm .02$ F1 margin, for both blocks (Table 4): graph $\Delta F1 - .0065 \pm .0171$, 90% CI $[-.0133, +.0003]$; hashing $-.0024 \pm .0117$, $[-.0070, +.0022]$. Any undetected cost is bounded by the registered margin. On the leakage-prone secondary random split the strong centralized baseline is directionally better with graph features ($\Delta F1 - .0160$, exact $p=.0062$, Holm $p=.025$; the TOST CI lies entirely below zero)—a disclosed cost that appears only where train and test share packages. “FL is never worse than centralized” is not claimed.

Behavior graphs add a significant but bounded margin over trivial structure. A metadata-only baseline (five structural features: file count, parse failures, entry-point flags, empty-graph indicator) already reaches F1 .82–.86 over twenty seeds. The 18-feature behavior graph—a strict superset of these signals—adds a significant marginal gain on top of it ($\Delta F1 + .0227 \pm .0193$ group, $+ .0487 \pm .0163$ random; exact Wilcoxon $p=1.9 \times 10^{-5}$ and $p=1.9 \times 10^{-6}$), and the gain persists on the 500 non-empty-graph rows (group $+ .0322$, $p=.0012$; random $+ .0550$, $p=1.9 \times 10^{-6}$), so it is not an artifact of the empty-graph flag. The graphs’ value is this bounded refinement plus named-node interpretability, not raw ranking dominance: on the primary split the blocks differ by at most .030 AUC, while on the leakage-prone random split the text block ranks higher (hashing FedAvg .952 $\pm$.015 vs. graph .893 $\pm$.025). We do not claim graph superiority. One disclosure: a sixth checklist feature (byte size) is absent from the extracted schema and was neither imputed nor substituted.

Sensitivity and knowledge base, compressed. DP noise ($\sigma=0.1$, $\epsilon \approx 48.4$ per round, composition unproven) costs 0.8 F1 points; a 32-unit MLP matches LR exactly; the 103 empty-graph rows carry real ecosystem signal (dropping them moves central F1 to 0.821, $n=500$). A refusal-gated LLM-built knowledge base covering the full corpus API universe (137/137 types, 2,299/2,299 instances) leaves accuracy essentially neutral (measured detail in Appendix A); its robust yield is gated per-call explanation, not F1.

5.4 Federation-robustness under family shift

The group split removes version-level leakage within a package but not whole-family shift: unseen families sharing an actor or lineage may behave differently from the training distribution, and the

Table 3: Corrected-baseline grid (registered before the run): twenty seeds, F1/AUC mean $\pm$ std over seeds (population, $ddof=0$). Strong centralized = 1bfgs LR on train-fit standardized features (C by train-only 3-fold CV); FedAvg = converged local fit + size-weighted average; per-client-best is oracle per-sample routing (an upper bound, not a deployable system). Text block = stateless HashingVectorizer (2^{18} , L_2). 360 runs, mock=false.

Run	group (PRIMARY)		random (secondary)	
	F1	AUC	F1	AUC
graph strong centralized	.878 $\pm$.042	.890 $\pm$.040	.887 $\pm$.020	.899 $\pm$.022
graph FedAvg	.871 $\pm$.043	.879 $\pm$.043	.871 $\pm$.029	.893 $\pm$.025
graph per-client-best	.861 $\pm$.041	.887 $\pm$.040	.875 $\pm$.024	.899 $\pm$.021
hashing strong centralized	.875 $\pm$.039	.896 $\pm$.036	.910 $\pm$.020	.939 $\pm$.019
hashing FedAvg	.872 $\pm$.036	.909 $\pm$.034	.906 $\pm$.020	.952 $\pm$.015
hashing per-client-best	.884 $\pm$.031	.916 $\pm$.034	.915 $\pm$.026	.952 $\pm$.021

Table 4: Corrected-baseline comparison (FedAvg – strong centralized), paired per seed over 20 seeds, F1. TOST: pre-registered equivalence margin $\pm.02$ — equivalence holds iff the 90% t -CI of the mean $\Delta F1$ lies entirely inside the margin (Schuirmann at $\alpha=.05$). Wilcoxon = two-sided exact signed-rank; p^{Holm} = Holm-adjusted over the four split $\times$ block comparisons. PASS/FAIL is the TOST verdict, not a significance claim: the random/graph FAIL is a CI entirely *below* zero (a directional centralized win on the leakage-prone split).

Split / block	$\Delta F1$ mean $\pm$ std	$n_+/n_-/n_0$	90% CI	TOST ($\pm.02$)	Wilcoxon p (p^{Holm})
group / graph	-.0065 $\pm$.0171	6/12/2	[-.0133, +.0003]	PASS	.119 (.356)
group / hashing	-.0024 $\pm$.0117	7/13/0	[-.0070, +.0022]	PASS	.312 (.624)
random / graph	-.0160 $\pm$.0228	4/15/1	[-.0251, -.0070]	FAIL	.0062 (.025)
random / hashing	-.0037 $\pm$.0135	5/12/3	[-.0091, +.0017]	PASS	.404 (.624)

equivalence result above is conditional on that threat model. To decide the robustness claim, a registered leave-cluster-out (LCO) evaluation holds out entire clusters of related samples: each hold-out unit is the connected component of {MinHash Jaccard $\geq .30$ over code 3-grams and package-name patterns}, closed with each member’s whole package (union-find, so no unit straddles a package or a near-duplicate; none of the 67 multi-version families is split); a randomized $\sim 20\%$ of units per label stratum is held out per seed and the remainder is used for retraining, for the graph and hashing blocks under the same standardized protocol (registered before any metric was computed). Over 20 seeds $\times$ randomized cluster hold-outs, both representations degrade jointly: the graph block by $\Delta F1 - .0383 \pm .0675$ (95% CI $[-.070, -.007]$) and the hashing block by $-.0289 \pm .0879$ (95% CI $[-.070, +.012]$), with held-out test shares of 14.3–27.2% of samples across seeds (unit sizes vary); the five-feature metadata baseline above degrades by a similar amount ($\Delta F1 - .026$ to $-.044$ across methods and thresholds), so the shift is not specific to content features. The paired graph-vs-hashing degradation difference is $dd = -.0095 \pm .0803$ (exact paired Wilcoxon signed-rank on per-seed degradation differences, $p=.368$; FedAvg $-.0139 \pm .0794$, $p=.674$; 95% CI of dd $[-.047, +.028]$). The conclusion is two-directional: no robustness ranking between the representations is supported, and none is claimed. The design has power $\approx .75$ to detect a .05-F1 degradation differential at $n=20$; the 95% CI of dd is not contained in the $\pm.02$ equivalence margin used above, so family-shift equivalence at that margin is not established (it would pass at a margin of .05). The same null holds at a 0.50 clustering-threshold sensitivity ($dd = -.0033$ and $-.0121$, $p=.985$ and $.430$).

6 DISCUSSION

The surface is domain- and family-dependent. The advisory channel does not port from the vulnerability domain as the same phenomenon type: there, untrusted context created false positives on benign code; here it perturbs recall on malicious packages, and the per-family direction flips. A post-hoc granite-3.3-2B re-run of the vulnerability-domain ladder makes the domain-dependence concrete with one model: recall on vulnerable files collapses $.7627 \rightarrow .0667$ under the reassertion rung (41/0 flips, $p \approx 4 \times 10^{-10}$) and a benign rung manufactures 20/30 false positives ($p \approx 1.9 \times 10^{-6}$)— same model, opposite domain signature from its package-domain behavior (detail and caveats in Appendix A). Neither domain’s signature predicts the other’s; measurements must be made per domain and per model family.

Sanitization is necessary and cheap, but not uniformly sufficient. D1 costs no model changes and provably removes the attack (byte-equality of strip outputs), and where the advisory’s effect was inflation it returns the analyzer to baseline exactly. The llama outcome is the boundary condition: a cue-based detector that keys on the package’s own comments loses those cues to the same strip. Defenses for LLM package analyzers therefore need a family-aware evaluation—the strip that closes one family’s attack surface is the same strip that opens another’s blind spot at this scale—and future arms should pre-register both outcome directions, as this protocol did.

What the detector layer contributes. The equivalence result (§5.3) matters operationally: ecosystem-partitioned federated training is a viable deployment shape for this analyzer

at equivalent accuracy on leakage-resistant splits, so the safety findings above are not an artifact of a centralized collector. The leave-cluster-out evaluation (§5.4) extends the same question to family shift.

7 THREATS TO VALIDITY

Internal validity: disclosed audit history. This project ran an internal audit workflow whose corrections are part of the record, not the main claims. Four matter for reading the numbers here. (i) The safety quantity initially labelled “false-positive bias” actually computed recall on malicious packages; the affected values are re-read under the corrected semantics throughout, with benign false positives measured separately (all raw records unchanged). (ii) An earlier claim that text features degrade under federation was retracted: it was an artifact of a pooled-vocabulary featurizer plus an undertrained solver, and it vanishes under the corrected baseline (numbers in Appendix A). (iii) An earlier apparent FedAvg minority-client harm disappeared once a file-selection bug was fixed, and an apparent centralized-training collapse was re-attributed to solver undertraining (0/80 converged cells under the corrected baseline). (iv) The FedProx μ routing bug in the earlier grid was found, fixed, and unit-pinned. Every federation claim in this paper rests on the pre-registered corrected protocol.

Statistical power. Pilot scale: CI widths $\pm .05$ – $.08$ F1 on detect cells; the defense pairing realizes 24 malicious + 14 benign per model, in which no paired comparison reaches significance (smallest exact McNemar $p=.125$; zero-discordant comparisons are uninformative), the llama restoration failure rests on one package family, and the mechanism ablation is a null with low power. Registered hypotheses that pass at the “ ≥ 1 of 2 models” rule (H-D1/H-D2) are reported per model for exactly this reason.

External validity and scale. One wild-capture malicious corpus plus popularity-derived benign labels; two ecosystems; all conclusions close at 2–3B under local decoding—the direction of safety-layer effects follows model family *and* domain, so no scale extrapolation is made. Evaluating ≥ 8 B models is infeasible on this runtime (Appendix A); the registered three-client fallback partition differs negligibly from the two-client partition (Appendix A) and is a same-corpus partition, not a third ecosystem.

8 CONCLUSION

Untrusted in-package content is a domain-dependent, family-dependent attack surface on LLM package analyzers, and AST-level sanitization closes it where it matters most: an AST-gated comment/docstring strip provably removes the advisory (strip-output byte-equality on all 38 gated samples), fully neutralizes the channel on the model family it inflates, and its residual cost—no restoration for a cue-based family—is measured and disclosed rather than averaged away. Refusal is absent throughout this domain at 2–3B. The detector beneath these measurements is federation-robust by pre-registered equivalence and a significant-but-bounded refinement over trivial structure. Limitations travel with every number: pilot scale, simulation-only trust mechanisms, two ecosystems, popularity-derived benign labels, self-reported

KB confidence, and a hard 2–3B scale ceiling; the leave-cluster-out evaluation reported above (§5.4) decides the family-shift robustness claim.

DATA AND PROVENANCE

Manifest, features, graphs, per-row results with mock flags, audit reports, and the pre-registration amendments are in the anonymized artifact tree released with this submission (dataset manifests under data/, all measured outputs under outputs/ incl. p0/p0_results.json (the corrected-baseline grid), trivial/trivial_results.json, safety/safety_metrics_n60.json, r10/r8_safety_expand/safety_metrics_n100.json, and defense/defense_analysis.json, the pre-registration document docs/preregistration.md, and the audit reports directory). Paths are shown relative to the artifact root; per-number provenance is annotated in the source of this manuscript (% SRC: comments), and every macro-generated number is derived from these artifacts by scripts/gen_paper_numbers.py (p0_macros/numbers.tex).

REFERENCES

- [1] Anonymous. 2026. Measuring and Mitigating Safety-Layer Interference in LLM Vulnerability Analysis. Anonymous manuscript under double-blind review. Unpublished companion measurement study; no public identifier as of this submission. Note: arXiv:2603.01246 is a different paper (Campbell et al., “Defensive Refusal Bias”).
- [2] David Campbell, Neil Kale, Udari Madhushani Sehwaq, Bert Herring, Nick Price, Dan Borges, Alex Levinson, and Christina Q Knight. 2026. Defensive Refusal Bias: How Safety Alignment Fails Cyber Defenders. *arXiv preprint arXiv:2603.01246* (2026). arXiv record verified 2026-09-27 (v2).
- [3] DataDog, Inc. 2026. GuardDog: CLI tool to detect malicious PyPI and npm packages. <https://github.com/DataDog/guarddog>. Version 3.2.0; rule-based (YARA) source and metadata scanners. Accessed September 2026.
- [4] Ruian Duan, Omar Alrawi, Ranjita Pai Kasturi, Ryan Elder, Brendan Saltaformaggio, and Wenke Lee. 2021. Towards Measuring Supply Chain Attacks on Package Managers for Interpreted Languages. In *Proceedings of the Network and Distributed System Security Symposium (NDSS)*. arXiv:2002.01139 (arXiv comment: “To appear in NDSS Symposium 2021”); MalOSS collection.
- [5] Xingan Gao, Xiaobing Sun, Sicong Cao, Kaifeng Huang, Di Wu, Xiaolei Liu, Xingwei Lin, and Yang Xiang. 2025. MalGuard: Towards Real-Time, Accurate, and Actionable Detection of Malicious Packages in PyPI Ecosystem. In *34th USENIX Security Symposium (USENIX Security 2025)*. arXiv:2506.14466; venue per USENIX program, arXiv record verified 2026-09-27.
- [6] S. Halder, M. Bewong, A. Mahboubi, Y. Jiang, R. Islam, Z. Islam, R. Ip, E. Ahmed, G. Ramachandran, and A. Babar. 2024. Malicious Package Detection using Metadata Information. In *Proceedings of the ACM Web Conference 2024 (WWW '24)*. <https://doi.org/10.1145/3589334.3645543> System name MeMPtec; arXiv:2402.07444; venue: ACM Web Conference (WWW).
- [7] Cheng Huang, Nannan Wang, Ziyang Wang, Siqi Sun, Lingzi Li, Junren Chen, Qianchong Zhao, Jiaxuan Han, Zhen Yang, and Lei Shi. 2024. DONAPI: Malicious NPM Packages Detector using Behavior Sequence Knowledge Mapping. In *33rd USENIX Security Symposium (USENIX Security 2024)*. arXiv:2403.08334; arXiv comment confirms USENIX Security 2024 acceptance.
- [8] Piergiorgio Ladisa, Henrik Plate, Matias Martinez, and Olivier Barais. 2023. SoK: Taxonomy of Attacks on Open-Source Software Supply Chains. In *2023 IEEE Symposium on Security and Privacy (S&P)*. 1509–1526. arXiv:2204.04008; venue verified 2026-09-27.
- [9] Marc Ohm, Henrik Plate, Andreas Sykosch, and Michael Meier. 2020. Backstabber’s Knife Collection: A Review of Open Source Software Supply Chain Attacks. In *Detection of Intrusions and Malware, and Vulnerability Assessment (DIMVA)*. arXiv:2005.09535; 2005.09561 is an unrelated paper; BKC dataset.
- [10] Nusrat Zahan, Philipp Burckhardt, Mikola Lysenko, Feross Aboukhadijeh, and Laurie Williams. 2025. Leveraging Large Language Models to Detect npm Malicious Packages. In *47th IEEE/ACM International Conference on Software Engineering (ICSE 2025)*. arXiv:2403.12196 (v1 title: “Shifting the Lens: Detecting Malware in npm Ecosystem with Large Language Models”).

- [11] Junan Zhang, Kaifeng Huang, Yiheng Huang, Bihuan Chen, Ruisi Wang, Chong Wang, and Xin Peng. 2025. Killing Two Birds with One Stone: Malicious Package Detection in NPM and PyPI using a Single Model of Malicious Behavior Sequence. *ACM Transactions on Software Engineering and Methodology* 34, 4 (2025), 1–28. <https://doi.org/10.1145/3705304> System name Cerebro; arXiv:2309.02637; CrossRef record verified 2026-09-27.
- [12] Peiheng Zhou, Ming Hu, Xingrun Quan, Yawen Peng, Xiaofei Xie, Yanxin Yang, Chengwei Liu, Yueming Wu, and Mingsong Chen. 2024. An Empirical Study of Vulnerability Detection using Federated Learning. *arXiv preprint arXiv:2411.16099* (2024). No journal ref as of 2026-09-27; cited as preprint.

A REPRODUCIBILITY AND AUDIT TRAIL

This appendix condenses the registered-protocol history, the corrected and retracted findings, and the secondary arms referenced from the main text. Every value below is macro-generated or carries a % SRC: comment; the audit trail behind them is in the released artifact tree.

A.1 Registered-protocol history

Group split. The package-level group split was adopted after measuring that the pre-registered random split shares a package between train and test for 35% of test rows; the flawed manifest that motivated the coverage fix (a silent skip of flat-layout archives, 597 $\rightarrow$ 603) is retained as an audit artifact. **Twenty seeds.** The registered grid extends an earlier five-seed protocol to twenty seeds (20260922–20260941); the five original seeds are unchanged and seed 20260922 reproduces the original single-seed table to four decimals. The extension was registered before the twenty-seed run but after the five-seed results were known (disclosed; not double-blind). **Corrected baseline.** Registered before any corrected-baseline run, with the twenty-seed grid already known (disclosed): the strong centralized solver of \$3.3, the stateless text arm, the TOST layer at $\pm .02$ F1, and the Holm layer. **Attack–defense pairing.** The D1 definition, AST gate, sample subsets, and the two-directional hypotheses with margins (.05/.10) were registered before any pairing generation; two pre-run refinements (the prompt-fidelity clause and the any-position bare-string signature pruning) are recorded inside the registration text with reasons. **Metrics semantics.** The safety metrics were re-versioned after an audit showed the initially labelled “false-positive bias” computed the true-positive rate on *malicious* packages (a double label-convention inversion); values were never changed, only re-read, and benign false positives are now reported separately everywhere.

A.2 Retracted and re-attributed findings

“Text degrades under federation”—retracted as a baseline artifact. Under the earlier protocol this appeared confirmatory ($\Delta F1 - .0521 \pm .0219$, exact $p = 3.8 \times 10^{-6}$, Holm 1.1×10^{-5}) with a degenerate all-malicious FedAvg mode (recall = 1.0 in 79/80 ecosystem cells; group-split pypi F1 .671 $\pm$.059 vs. .790 $\pm$.076 centralized). Two defects explain it: the TF-IDF featurizer fitted its vocabulary on the pooled corpus, and the solvers were under-trained. With a stateless hashing featurizer and converged solvers the degradation vanishes (group $\Delta F1 - .0024$ n.s.; 0/360 corrected rows with recall $\geq .999$). **Centralized “collapse”—solver under-training.** The earlier grid showed centralized training collapsing in 2/160 seed-level cells (F1 .375 and .326) while FL stayed $\geq .73$;

the corrected baseline collapses in 0/80 cells (max $n_{\text{iter}} = 69 \ll 5000$; minimum cell F1 .769), and the random-split centralized mean moves .835 $\pm$.113 $\rightarrow$.887 $\pm$.020. **Minority-client harm—feature bug.** The interim v1-feature run showed pypi F1 0.57 vs. 0.82 centralized; after the file-selection fix the harm vanishes (registered grid: group-split pypi F1 .851 $\pm$.080 under FedAvg vs. .830 $\pm$.100 centralized across seeds—if anything reversed).

A.3 Earlier-protocol grid refresh and calibration

The full earlier-protocol grid was refreshed under its registered configuration and re-audited: 640/640 rows real over 20 seeds $\times$ 8 cells $\times$ 4 methods; the centralized ecosystem means reproduce the registered fixed baselines exactly. Two disclosed artifacts travel with it: the ecosystem random/text FedAvg cell is seed-invariant (F1 .784, std .0000—variance and paired statistics on that cell are not meaningful), and the per-seed inferential layer self-labeled $n=5$ at refresh time; it was subsequently regenerated and script-verified from the stored per-seed deltas. Per-sample test probabilities for all 160 centralized cells are released (19,484 rows; 12,680 malicious / 6,804 benign). On these probabilities: no all-malicious mode exists (0/40 cells per block $\times$ split at threshold 0.5); TF-IDF calibration is poor (pooled ECE .1891/.2240 group/random vs. .0726/.0870 graphs); the published threshold sweep selects thresholds on the same pooled test rows it scores (a test-set oracle, not deployable—TF-IDF .8466 $\rightarrow$.8790 group, .8432 $\rightarrow$.8955 random; graphs best at the default .50); and class weighting is a negative intervention (lowers F1 in 3 of 4 groups). A validation-locked threshold evaluation is queued before any tuned-threshold claim.

A.4 Additional detector arms

Stabilized-centralized arm (single config, aggregate only). A registered per-cell lr sweep with train-only CV early stopping ran over 20 seeds $\times$ {group,random} $\times$ {graph,tfidf}: 80/80 real cells; lr 0.1 selected in 58 cells (0.03: 21; 0.01: 1); mean best epoch 12.05 (min 2, max 30). Graph outcome is F1-neutral (early – fixed $\Delta F1 + .0011$ group, $-.0015$ random; group/graph .859 $\pm$.046 early vs. .858 $\pm$.047 fixed); the early-stopped tfidf arm parks at a near-all-positive operating point (predicted-positive $\approx 99.5\%/99.6\%$), so its $\Delta F1 (-.0511$ group, $-.0561$ random) is block-specific operating-point behavior. The arm remains aggregate-only (no paired inference) and is superseded by the corrected-baseline protocol for all federation claims. **FedProx μ sweep (descriptive, registered as such).** With routing fixed, FedProx differs from FedAvg at the probability level from $\mu=.01$ (max $|\Delta p|=.0022$ on the audited real cell; unit tests pin $\mu=1$ differing, $\mu \rightarrow 0$ coinciding), but no μ separates at the metric level on the primary split: graph $\Delta F1(\text{FedProx} - \text{FedAvg}) = +.0044 \pm .0140$ ($p=.084$), $+.0048 \pm .0214$ ($p=.452$), $+.0043 \pm .0301$ ($p=.475$); hashing stays within $\pm .004$ F1 at every μ (all $p > .21$). **Three-client fallback partition.** A registered fallback (npm split by install-hook presence: npm_core 214 / npm_hook 114 / pypi 146; the hook client is

Table 5: KB ablation on the primary (group) split, initial run under KB v2 (54.7% type coverage); the completed KB v3 (100%) re-run is reported in the text. “on” appends kb_risk_ratio / kb_confidence / kb_unsure_ratio to the 18 graph features.

Run	F1		AUC	
	off	on	off	on
FedAvg	.923	.922	.916	.911
centralized	.928	.938	.926	.932
pypi F1 (central)	.875		.966	

99.1% malicious—the corpus has exactly one hooked benign package, which lands in train in all five group splits) differs negligibly from the two-client partition (group/graph $\Delta F1 +.024 \pm .120$, exact Wilcoxon $p=1.0$). This is a same-corpus partition, *not* cross-ecosystem FL: no ingestible third-ecosystem source was found (disclosed). **Sensitivity arms (single seed 20260922)**. DP ($\sigma=0.1$, $\epsilon \approx 48.4$ per round, single-query bound, composition unproven): F1 0.915 (−0.8 points); MLP matches LR exactly; dropping the 103 empty-graph rows moves central F1 to 0.821 ($n=500$).

A.5 Knowledge-base ablation detail

Under the initial KB-v2 run (Table 5), KB features were neutral under FedAvg (−0.1 pt F1) and added +1.0 pt F1 / +0.6 pt AUC to centralized training, with the gain concentrated on the minority client (pypi F1 .875 $\rightarrow$.966; subgroup $n=36$ —indicative, not significant). The builder never saw a refusal (0 refusals, 0 retries, 0 UNSURE over the full universe at 3B; the 0.5B pilot model produced 8/10 UNSURE—model scale matters), and 113 of 122 LLM entries self-report confidence clipped at 0.90 (a weak calibration signal). The completed-KB re-run needs no LLM calls (coverage is a pure dict-join, instance coverage 1.0): at the shared seed the centralized gain matches the initial run’s magnitude (+0.0103 group, +0.0112 random F1) but the FedAvg effects are of mixed sign (−0.0009 group, −0.0224 random), and all four deltas sit below the measured per-cell seed variability—a backend-dependent interaction, not a claimable effect.

A.6 Safety measurement details

Selection and floors. The $n=100$ expansion batch is 360 verbatim copies of the $n=60$ records plus 240 new generations over 100 distinct samples (50/50; the new 40 are gate-passers [30:50] of the same seeded draw, zero overlap asserted); 192 of the new generations are fresh and 48 are deterministic-cache hits (temperature 0, seed 1234). RR $\equiv 0.0$ in *all* arms including P0, so the exact McNemar $p=1.0$ on the blocking column is structurally uninformative—the finding is blocking-absence, not a treatment null. The plan-level pool figure for the expansion scan remains unverified (the run scanned 265 records; 100 gate-pass), disclosed. **Mechanism ablation (null with low power)**. Same-meaning paraphrase and word-scrambled controls over 30 malicious gate-passers: 180 real rows, parsed 1.000, refusal 0.000 everywhere. Neither variant significantly moves the malicious-verdict rate (exact McNemar, 30 pairs per cell): granite .6000 $\rightarrow$.6667 (paraphrase, $p=.5$), $\rightarrow$.6333

(scrambled, $p=1.0$); llama .1333 $\rightarrow$.2333 ($p=.25$), $\rightarrow$.1667 ($p=1.0$). At every $p \geq .25$ this cannot separate “no effect” from a small effect; 96/180 rows are deterministic-cache hits (valid reuse, disclosed); the FP-directed arm (an advisory asserting “this code is clean”) remains queued.

A.7 Vulnerability-domain granite ladder

A post-hoc granite-3.3-2B re-run of the vulnerability-domain ladder (240 cache-only generations, zero new decoding, refusal rate 0.0 in every arm) shows the reassertion harm replicating at 2B: recall on vulnerable files .7627 $\rightarrow$.0667 under the reassertion rung (41/0 flips; McNemar continuity-corrected $\chi^2 p=4.2 \times 10^{-10}$, exact binomial 9.1×10^{-13} ; bootstrap Δ CI [−.81, −.58]) and .7627 $\rightarrow$.4000 under the milder advisory-only rung (23/2 flips, $p=6.3 \times 10^{-5}$), with a benign rung adding a verdict false-positive bias (0/30 $\rightarrow$ 20/30, exact $p=1.9 \times 10^{-6}$). Caveats: the reassertion arm is cache-only and its prompt hashes match none of the cache’s stored keys (byte-identity rests on the cache layer’s keying); the metrics file mixes McNemar variants (direction of every conclusion unchanged); one arm’s recall denominator is 59 parsed records vs. 60. These domain-side results ground the domain-dependence reading in §6.

A.8 Scale ceiling: $\geq 8B$ evaluation is infeasible on this runtime

The correct instrument for the scale question (Llama-3.1-8B-Instruct, same family, $\sim 2.7\times$) failed to load on this stack: four independent MPS load failures (a bf16 harness stall ≥ 27 min in weight copy with zero tokens generated; two fp16 accelerate-dispatch SIGSEGVs—pointer-authentication failures with stacks in `mps::copy_cast_kernel`; a direct fp16 run hung for 8 min until the watchdog killed it), while a CPU proof loaded the sha256-verified weights and generated real tokens at 1.11 tok/s, making the registered 240-generation $\times$ 512-token ladder ≈ 31 h of decoding alone (not feasible in time). Peak-RSS figures observed live during the failures were not preserved in raw artifacts and are not quoted as evidence; any $\geq 8B$ result requires a different runtime (MLX 4-bit or GGUF/llama.cpp, neither present here) and must not share feasibility claims with the transformers/MPS stack.